

THE 12 REQUIREMENTS

Properly covering the 12 requirements of PCI-DSS, as well as what each consists of.





THE 12 REQUIREMENTS

THE 12 REQUIREMENTS GOALS

Our major goal in this module is to clarify the 12 requirements of PCI-DSS. This, includes, among others:

- Clarifying Requirements 1 and 2, about securing networks with NSCs and removing defaults from devices;
- Clarifying Requirements 3 and 4, about protecting stored and transmitted credit card data;
- Clarifying Requirement 5 and 6, about securing machines with anti-malware, and securing SW development itself;
- Clarifying Requirements 7 through 9, about access controls (limiting access, identifying access, physical access);
- Clarifying Requirements 10 and 11, about logging significant events, as well as monitoring devices/threats;
- Clarifying Requirement 12, about having an InfoSec policy;



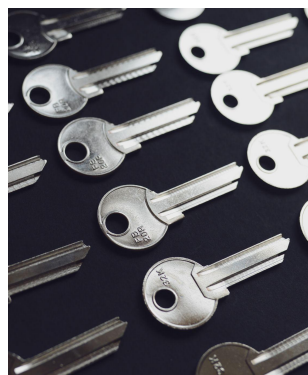
THE 12 REQUIREMENTS

To properly cover the 12 requirements,
we'll cover **twelve topics** - one for each:



REQ. 1: FIREWALL

Keeping a firewall configuration, as well as documentation and change management.



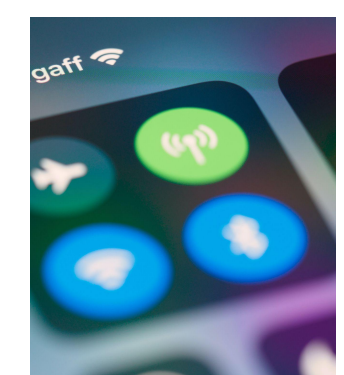
REQ. 2: NO DEFAULTS

Removing all default accounts, passwords and others from devices.



REQ. 3: STORED DATA

Protecting stored data in the database with strong encryption measures.



REQ. 4: TRANSM. DATA

Protecting data transmitted across networks with strong encryption and masking.



THE 12 REQUIREMENTS

To properly cover the 12 requirements,
we'll cover **twelve topics** - one for each:



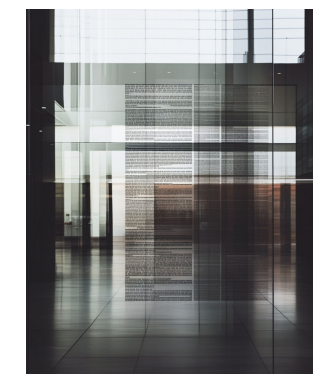
REQ. 5: NO MALWARE

Maintaining an antivirus program
to prevent malware from entering
your systems.



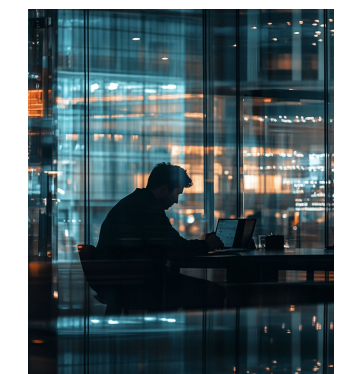
REQ. 6: SECURE DEV

Maintaining secure development
practices, as well as timely
patching of vulnerabilities.



REQ. 7: NEED-TO-KNOW

Restricting access to cardholder
data on a need-to-know basis.



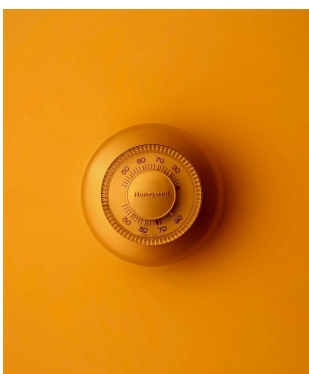
REQ. 8: IDENTIFYING

Procedures to attribute access to
specific users, for accountability.



THE 12 REQUIREMENTS

To properly cover the 12 requirements,
we'll cover **twelve topics** - one for each:



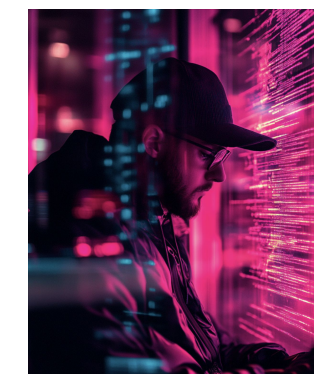
REQ. 9: PHYSICAL ACCESS

Restricting physical access to
rooms, physical media, and more.



REQ. 10: MONITORING

Proper logging of different
activities of different systems.



REQ. 11: REGULAR TESTS

Regularly testing, internally and
externally, to prevent intrusions.



REQ. 12: INFOSEC POLICY

Having an organisation-wide set of
policies and procedures for
information security.